
Uncovering Digital Information for Security Analysis

Footprinting, Reconnaissance, and Scanning

Melanie Seguin

Fullstack Academy | Cybersecurity Program

May 31, 2026

Target Systems	testphp.vulnweb.com fullstackacademy.com scanme.nmap.org
Lab Environment	Kali Linux 2025.2 ARM64 on Apple Silicon via Parallels Desktop
Tools Used	Whois, nslookup, Netcraft, Bing Search Operators, ping, nmap -sV
Deliverable	Passive OSINT Reconnaissance and Active Network Scanning Report

PART 1 PASSIVE RECONNAISSANCE / OSINT

All reconnaissance in this section was conducted using only publicly available information. No active probes or scanners were directed at any target system beyond standard web browsing and DNS resolution. The purpose was to replicate the passive information-gathering phase that a threat actor would perform before any active engagement against a target.

Step 1 Whois Lookup | Target: vulnweb.com

Screenshot: Whois result via whois.com

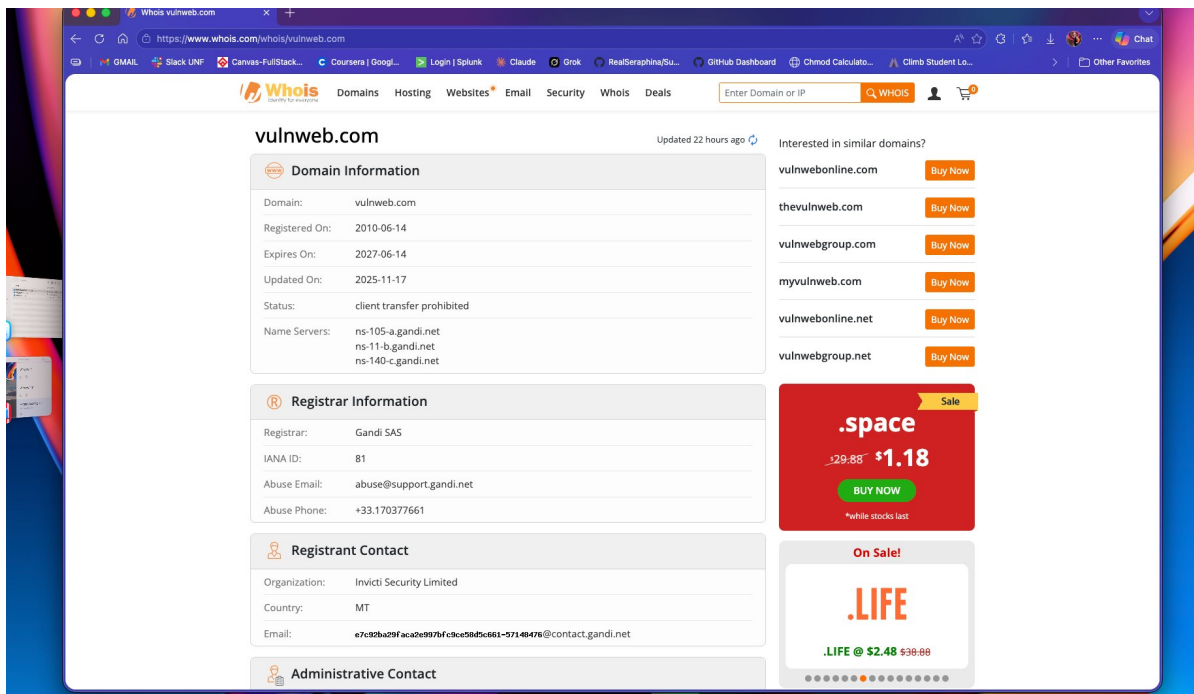


Figure 1.1 Whois lookup for vulnweb.com

Field	Value	Security Relevance
Registrar	Gandi SAS (IANA ID: 81)	A reputable EU-based registrar with a public abuse contact. No concerns from a registration standpoint.
Organization	Invicti Security Limited	Ownership is deliberately public, confirming this is an intentional security training platform operated by Invicti.
Created / Expires	June 14, 2010 / June 14, 2027	A long-standing, actively maintained domain. Not a newly registered or throwaway site.
Name Servers	ns-105-a.gandi.net ns-11-b.gandi.net ns-140-c.gandi.net	All nameservers fall under Gandi infrastructure with no suspicious delegations or split-DNS anomalies.

Step 2 DNS Lookup | Target: testphp.vulnweb.com

Screenshot: nslookup from Mac Terminal

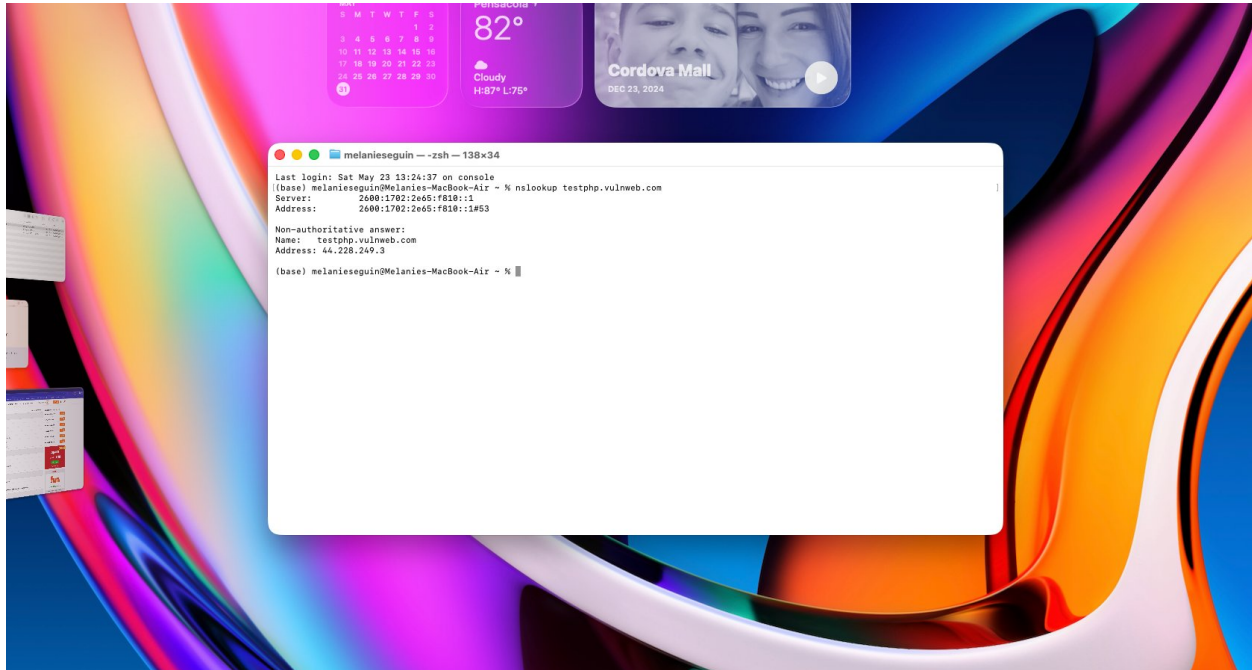


Figure 2.1 nslookup testphp.vulnweb.com from Mac Terminal

Key findings from the DNS lookup:

IP address resolved: 44.228.249.3. This is an Amazon Web Services address in the US West 2 (Oregon) region, confirmed by the reverse DNS entry ec2-44-228-249-3.us-west-2.compute.amazonaws.com.

Record type: A record, mapping the hostname directly to an IPv4 address with no CNAME chain. The response is non-authoritative, meaning a local resolver answered rather than Gandi's own nameservers. This is normal behavior for any standard DNS query.

Step 3 Hosting and Technology Stack | Target: testphp.vulnweb.com

Screenshots: Netcraft Site Report

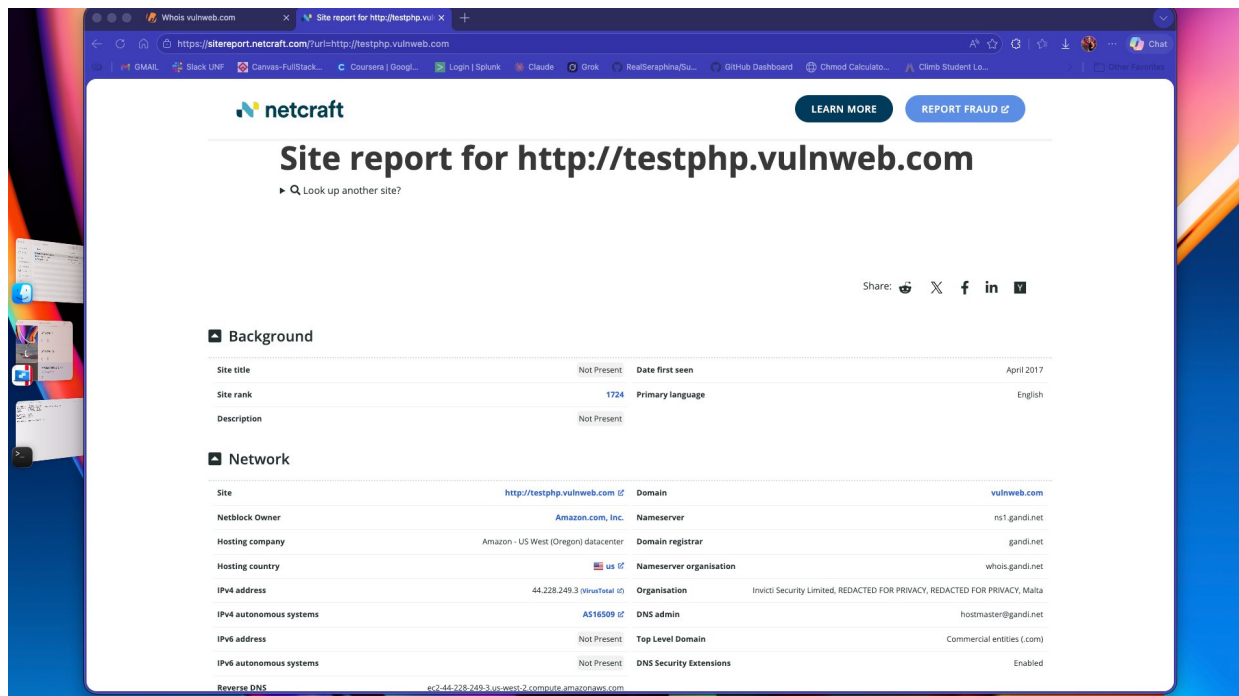


Figure 3.1 Netcraft Site Report showing network and hosting information

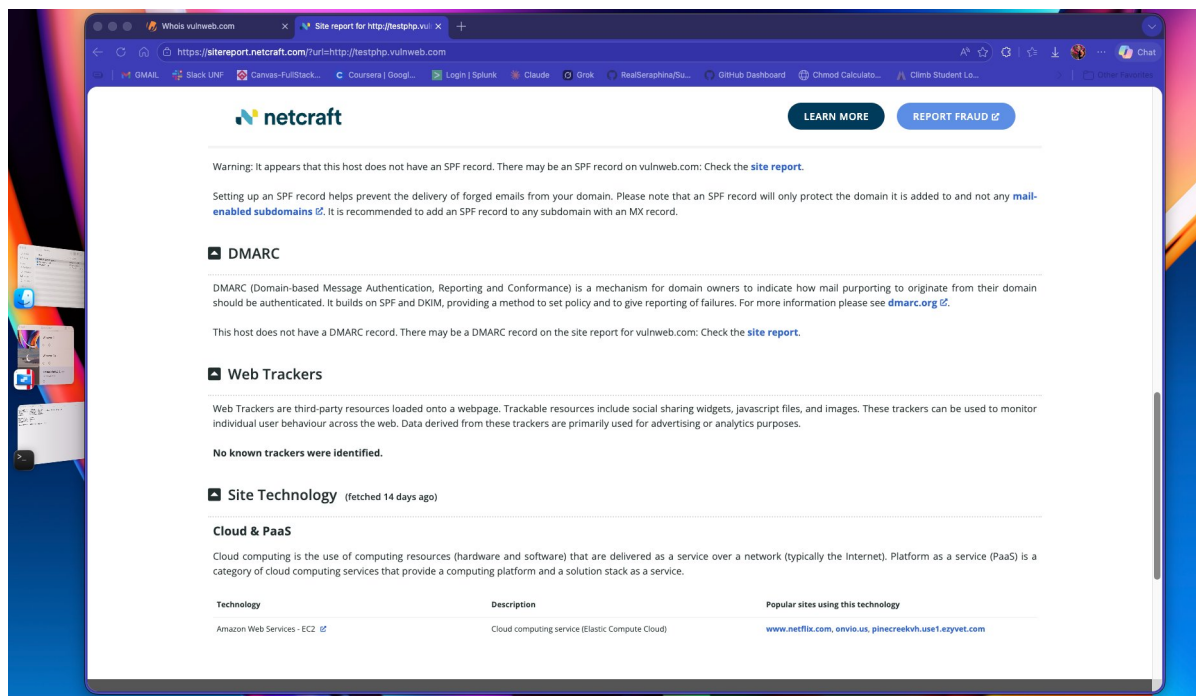


Figure 3.2 Netcraft report showing SPF and DMARC warnings and the Site Technology section

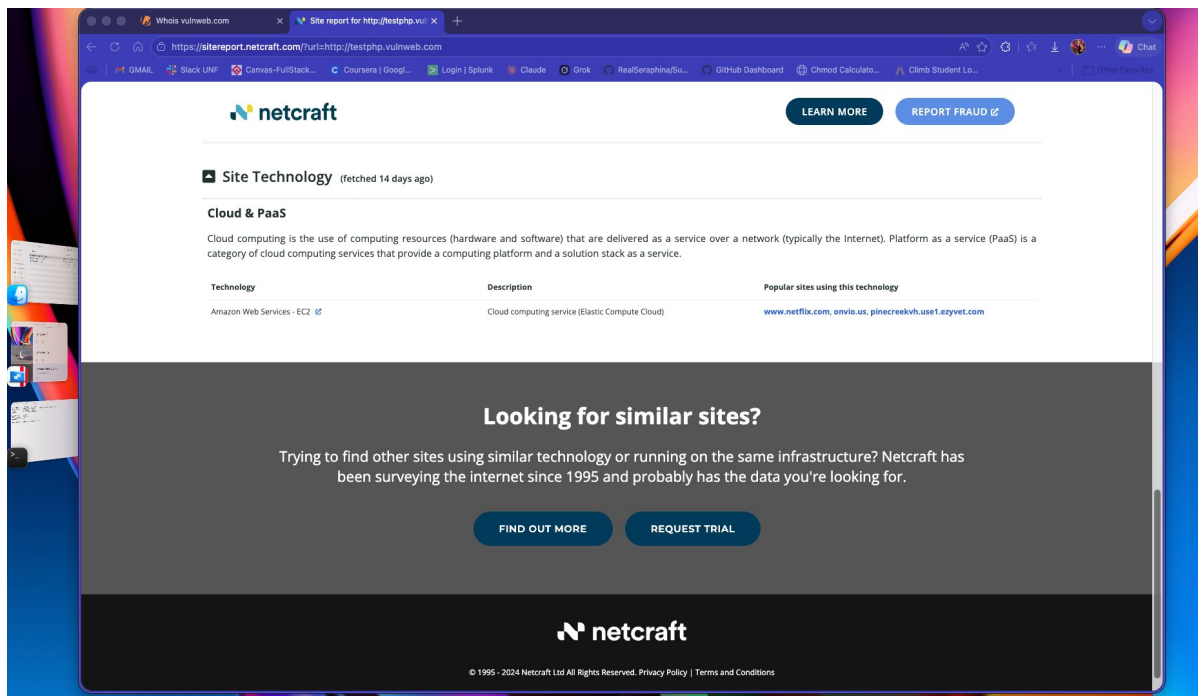


Figure 3.3 Netcraft report confirming AWS EC2 as the cloud platform

Key findings from the Netcraft report:

Hosting provider: Amazon Web Services Elastic Compute Cloud (EC2), US West region (Oregon datacenter). ASN AS16509 confirms Amazon as the network block owner.

Technology stack: Netcraft returned AWS EC2 as the only confirmed technology for this subdomain. No web server version or PHP version was exposed at the passive analysis level, which is a mild defensive positive since less surface information is available to a passive observer.

Security concern: Netcraft flagged the absence of both an SPF record and a DMARC record on `testphp.vulnweb.com`. Without these email authentication controls, spoofed email claiming to originate from this subdomain would not be automatically blocked or flagged by recipient mail servers.

Step 4 Search Operator Queries | Target: `testphp.vulnweb.com`

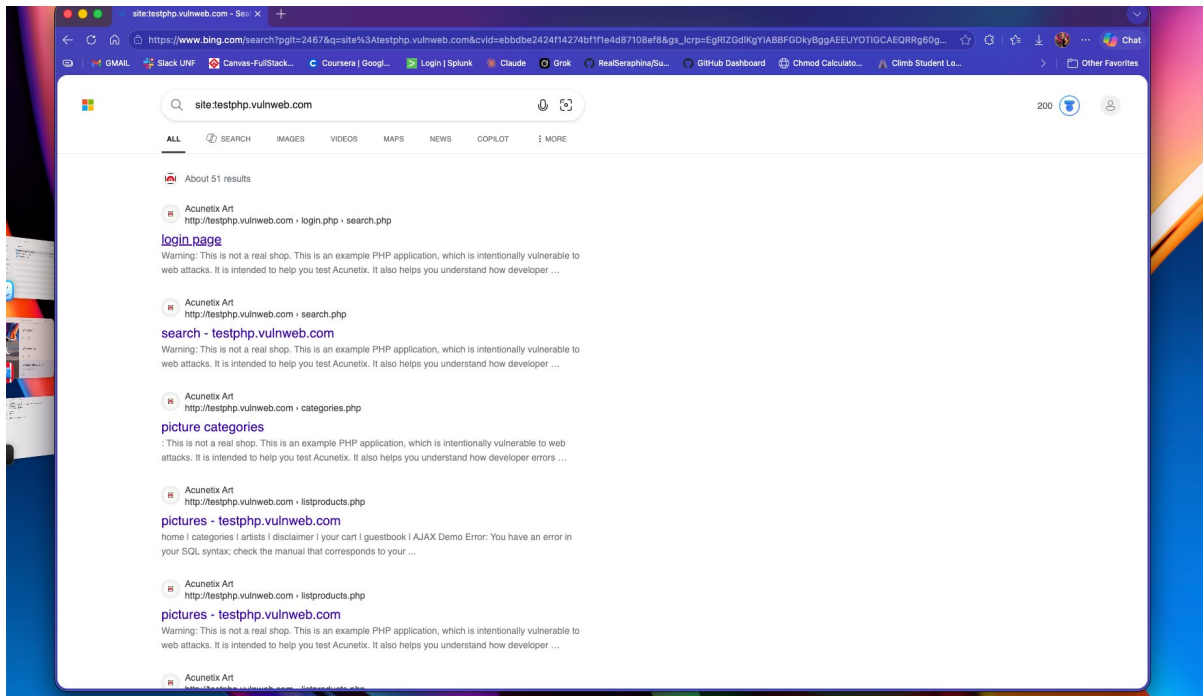


Figure 4.1 Query: `site:testphp.vulnweb.com`

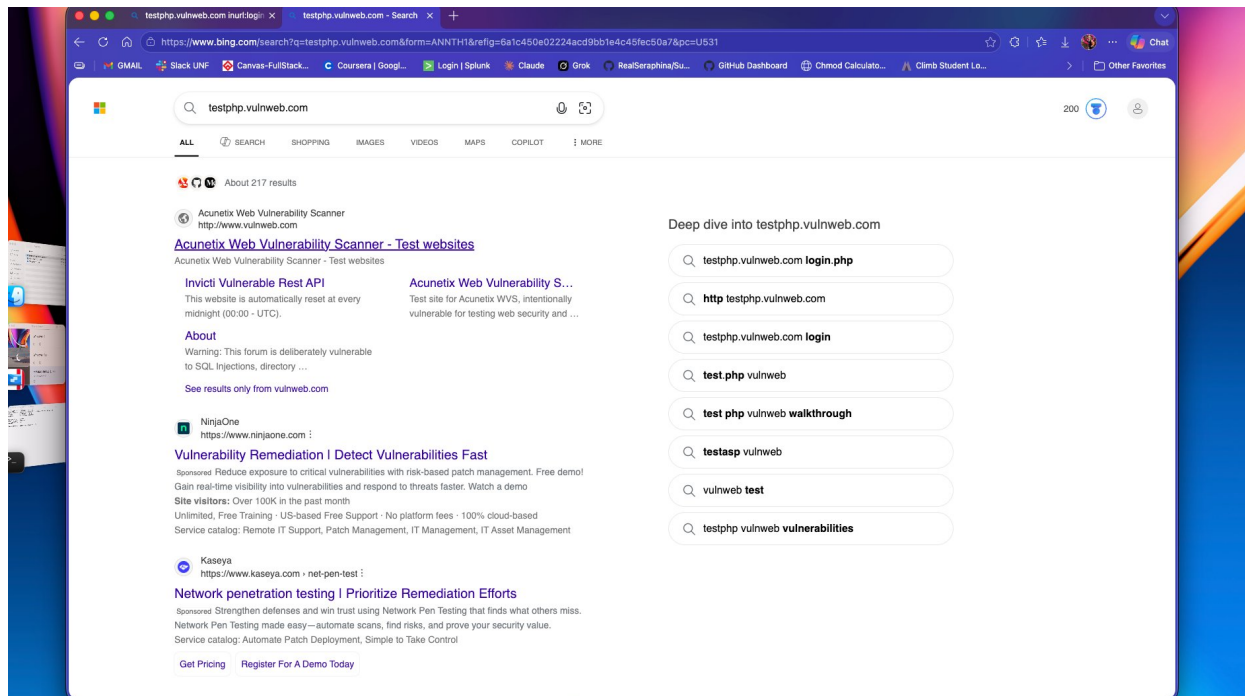


Figure 4.2 Query: `testphp.vulnweb.com` general search

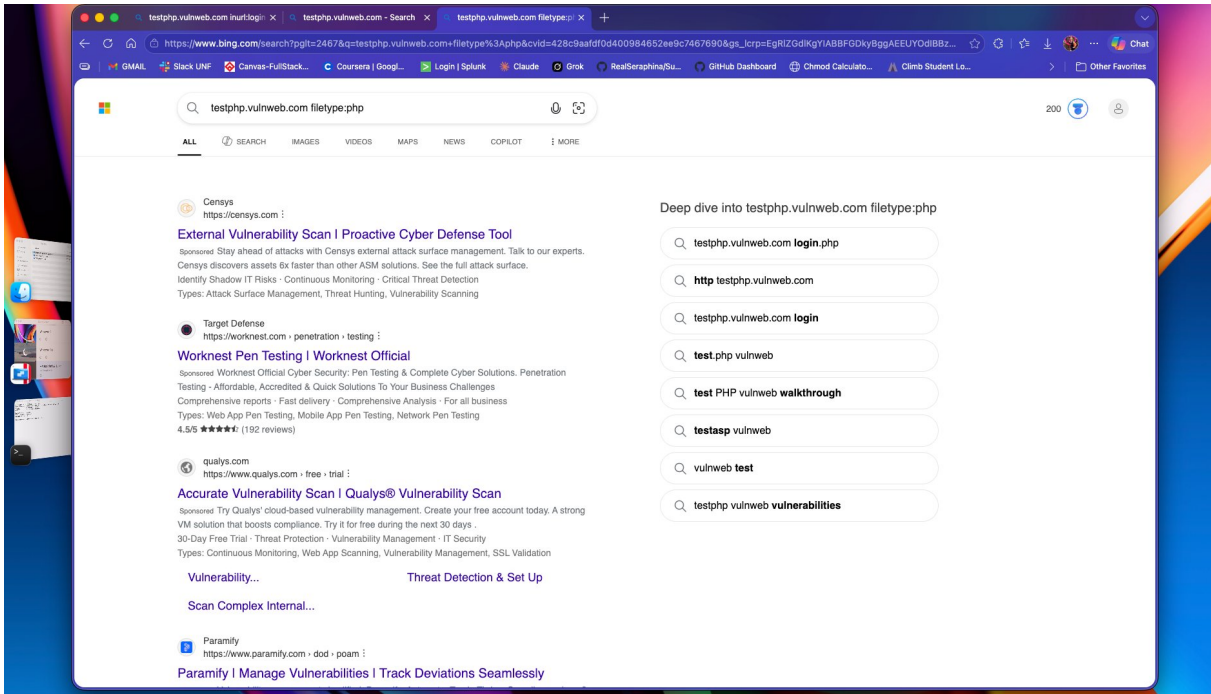


Figure 4.3 Query: testphp.vulnweb.com filetype:php

Query Used	Interesting Result Found	Why an Attacker or Defender Would Care
site:testphp.vulnweb.com	Approximately 51 indexed pages including login.php, search.php, categories.php, and listproducts.php. One snippet displayed a live SQL error: 'You have an error in your SQL syntax.'	The full page structure is publicly indexed and a live SQL error in a search snippet confirms the application leaks database messages. Any attacker would immediately target this for SQL injection without any active probing.
testphp.vulnweb.com (general)	Acunetix describes the site as intentionally vulnerable to SQL injection and directory traversal. About 217 results are indexed across security research platforms.	The attack surface is thoroughly documented publicly. An attacker would know exactly which vulnerability classes to attempt before sending a single packet to the server.
testphp.vulnweb.com filetype:php	Autocomplete and results prominently surface login.php as a frequently searched and indexed entry point.	PHP file enumeration exposes the backend technology and primary entry points. Login pages are the first target for authentication bypass, SQL injection, and credential stuffing.

Step 5 Light OSINT | Target: fullstackacademy.com (no scanning)

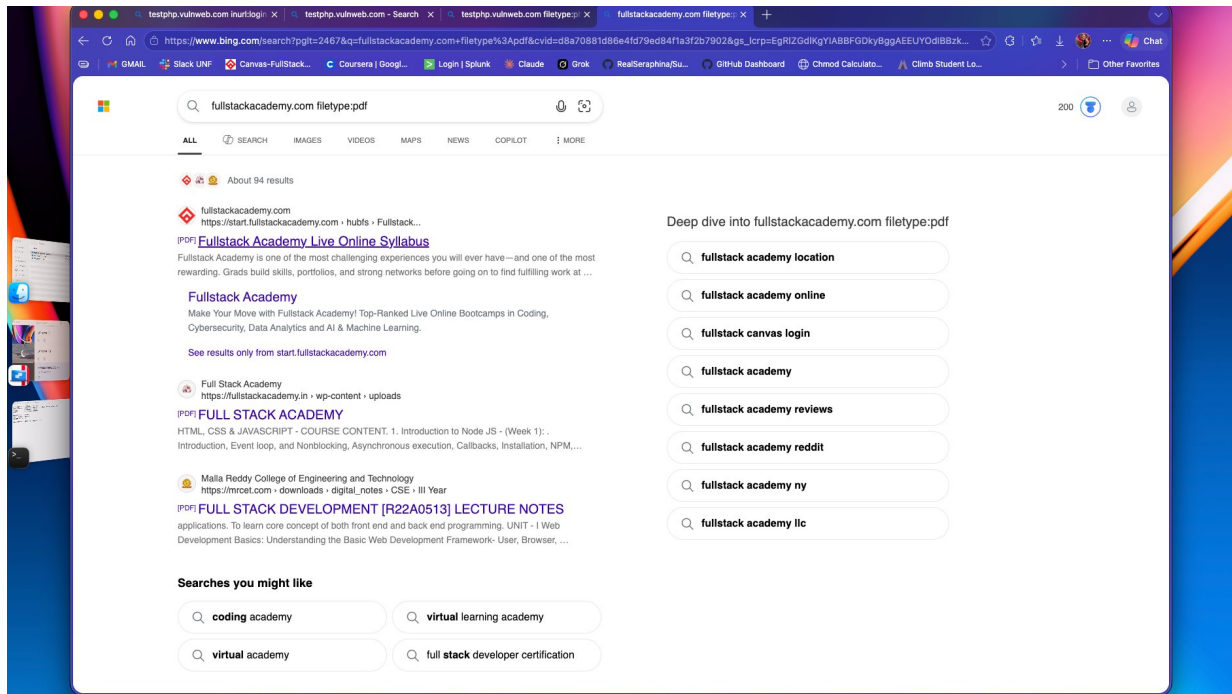


Figure 5.1 Query: fullstackacademy.com filetype:pdf

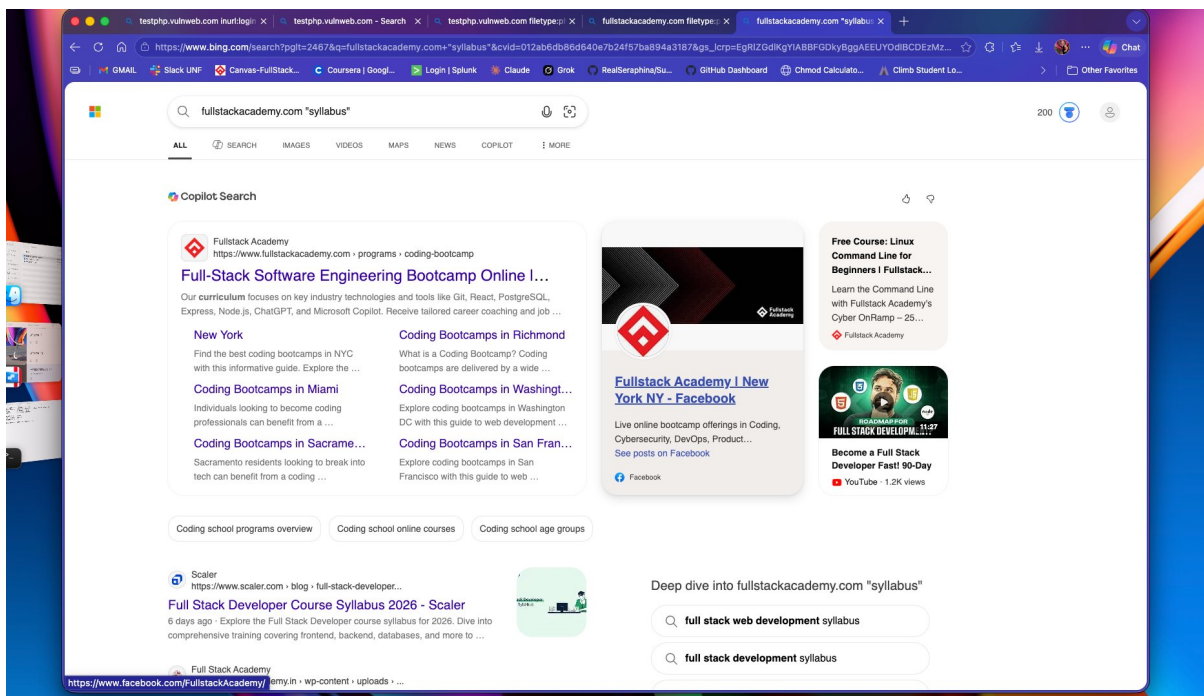


Figure 5.2 Query: fullstackacademy.com "syllabus"

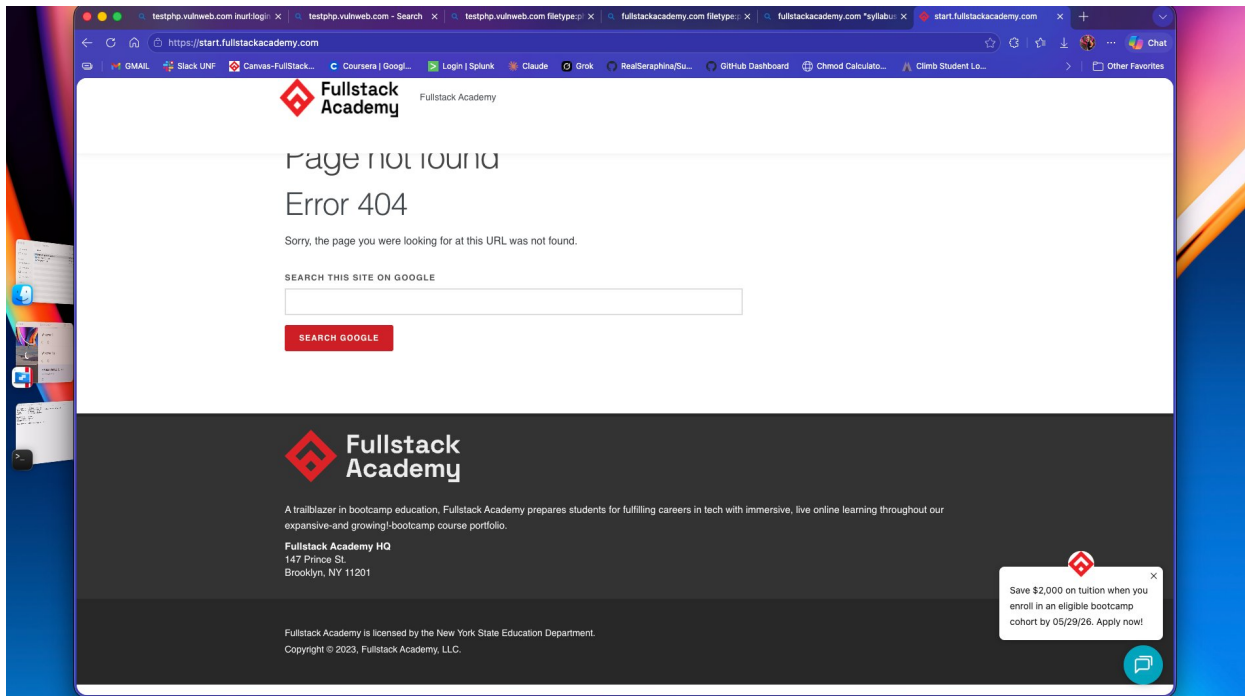


Figure 5.3 Query: `site:start.fullstackacademy.com` returning a 404 response

Query Used	Example Result Found	Why This Matters for Security and OSINT
<code>fullstackacademy.com filetype:pdf</code>	Fullstack Academy Live Online Syllabus PDF hosted on <code>start.fullstackacademy.com</code> . Approximately 94 PDF documents are indexed in total.	Publicly accessible curriculum documents expose the full technology stack being taught, including Node.js, React, PostgreSQL, and ChatGPT. A social engineer could use this to craft highly convincing phishing messages that reference specific course tools and content by name.
<code>fullstackacademy.com "syllabus"</code>	The Full-Stack Software Engineering Bootcamp page listing core technologies: Git, React, PostgreSQL, Node.js, ChatGPT, and Microsoft Copilot.	Technology stack disclosure allows an attacker to infer which platforms students and instructors actively use, enabling targeted phishing campaigns that mimic familiar tools such as GitHub notifications or Canvas assignment alerts.
<code>site:start.fullstackacademy.com</code>	The subdomain returns a 404 error at its root. The page footer reveals the physical headquarters address: 147 Prince St., Brooklyn, NY 11201.	An active subdomain returning a 404 at its root may indicate a misconfigured or partially decommissioned service, which represents a potential attack surface. The physical address disclosure also enables pretexting and in-person social engineering scenarios.

Step 6 Passive Reconnaissance Summary

testphp.vulnweb.com is highly visible from a passive perspective. Approximately 51 pages are indexed by search engines, including login and search endpoints, and live SQL error messages appear in search result snippets without any active probing. Domain ownership, hosting infrastructure, IP address, and documented vulnerability classes are all freely available. The absence of SPF and DMARC records adds an email spoofing risk on top of the already well-documented web application weaknesses.

fullstackacademy.com presents a moderate but meaningful passive footprint. Detailed curriculum PDFs, technology stack information, a physical headquarters address, and an active subdomain returning a 404 error are all reachable through search alone. While none of these individually constitute a direct technical vulnerability, together they form a rich intelligence profile that could support phishing, pretexting, or social engineering campaigns aimed at students and staff.

Top 5 Passive Findings

No.	Finding	Tool or Query	Why It Matters to a Defender
1	Live SQL error message visible in search result snippets for listproducts.php	site:testphp.vulnweb.com	Confirms the application leaks database error messages publicly. Defenders should suppress verbose errors and return only generic user-facing messages that reveal nothing about backend structure.
2	IP address 44.228.249.3 resolves to AWS EC2 Oregon, exposing full hosting infrastructure	nslookup and Netcraft	Cloud provider, region, and IP range are all identifiable passively, allowing an attacker to enumerate related assets and plan infrastructure-level targeting.
3	No SPF or DMARC records present on the testphp.vulnweb.com subdomain	Netcraft Site Report	Email spoofing from this address would not be blocked automatically. Production systems with this configuration are viable platforms for phishing infrastructure.
4	Publicly accessible curriculum PDFs expose the full technology stack taught at Fullstack Academy	fullstackacademy.com filetype:pdf	Spear-phishing campaigns targeting students become significantly more convincing when attackers can reference specific tools and course content by name.
5	start.fullstackacademy.com is active but returns a 404 at its root; physical HQ address is exposed in the page footer	site:start.fullstackacademy.com	Active subdomains with incomplete configurations are a recognized attack surface. Physical address disclosure also enables pretexting and in-person social engineering.

Recommended follow-up action for a defender: Conduct a full DNS audit across both domains to implement SPF, DKIM, and DMARC records on all active subdomains. Decommission or properly secure the start.fullstackacademy.com subdomain. Configure the web application to suppress verbose database error messages at the application layer, returning only generic responses that do not reveal backend technology, query structure, or table names.

PART 2 ACTIVE RECONNAISSANCE / SCANNING

All active scanning in this section was performed against `scanme.nmap.org`, a publicly sanctioned target maintained by the nmap project specifically for security practice and testing. This substitution was made per the lab instructions, which explicitly permit the use of `scanme.nmap.org` when the primary Metasploitable target is unavailable. Metasploitable 2 could not run in this environment because it is an x86 (Intel) virtual machine image and is architecturally incompatible with Apple Silicon ARM64. All scans were executed from Kali Linux 2025.2 ARM64 running inside Parallels Desktop on macOS.

Step 7 Confirm Connectivity | Kali to `scanme.nmap.org`

Screenshot: Kali Linux 2025.2 ARM64 terminal

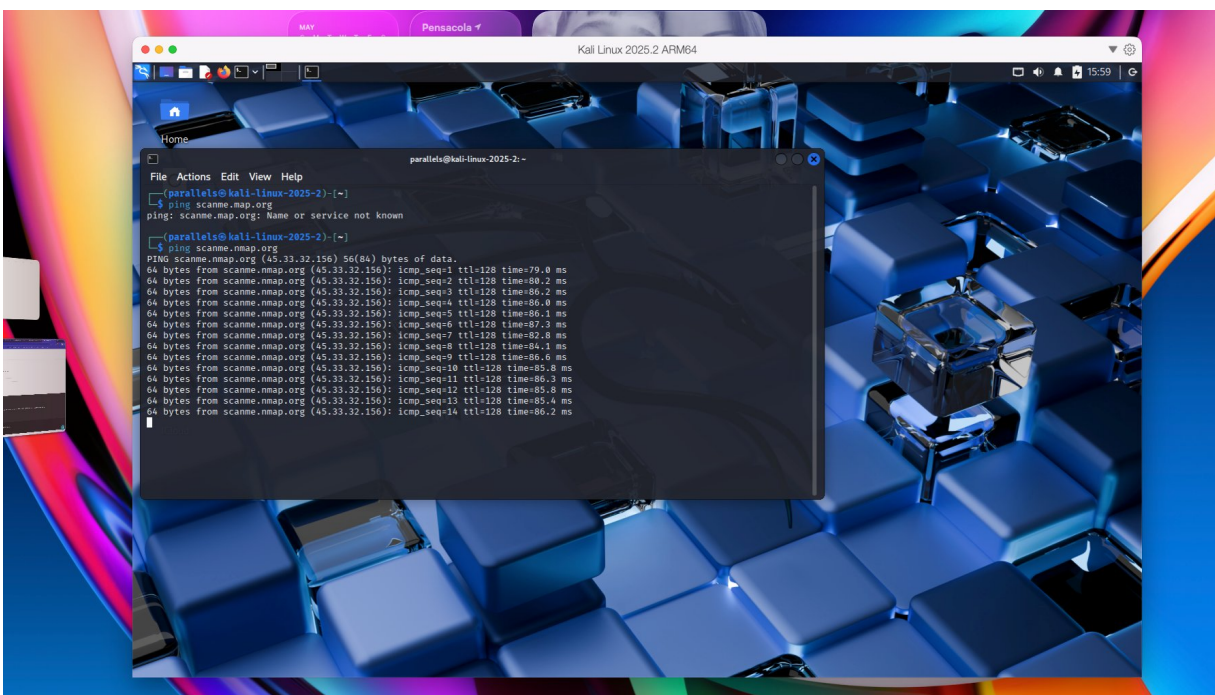


Figure 7.1 Kali Linux 2025.2 ARM64 terminal with `nmap -sV` command entered

Screenshot: Successful ping to `scanme.nmap.org`

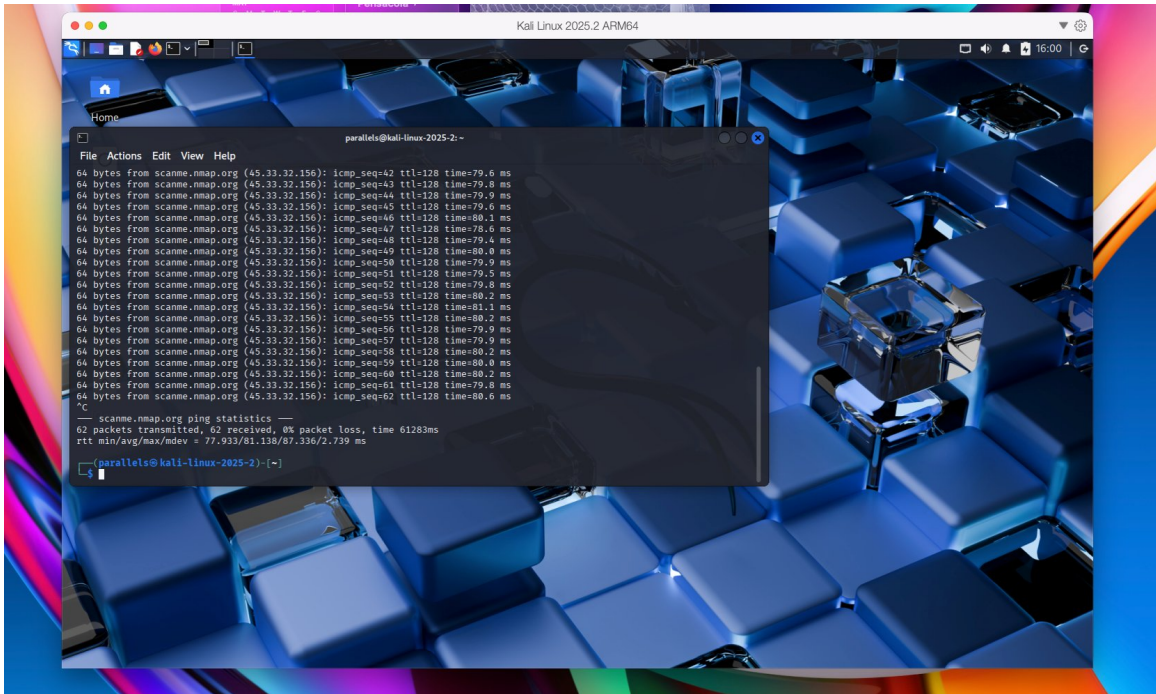


Figure 7.2 ping scanme.nmap.org showing 62 packets transmitted, 62 received, 0% packet loss

Connectivity results:

Target IP resolved: 45.33.32.156

Packet loss: 0 percent. 62 packets transmitted and 62 received.

Round-trip time: minimum 77.9ms, average 81.1ms, maximum 87.3ms. A stable, low-loss connection was confirmed.

Step 8 nmap Service Version Scan | Target: scanme.nmap.org

Screenshot: Full nmap output

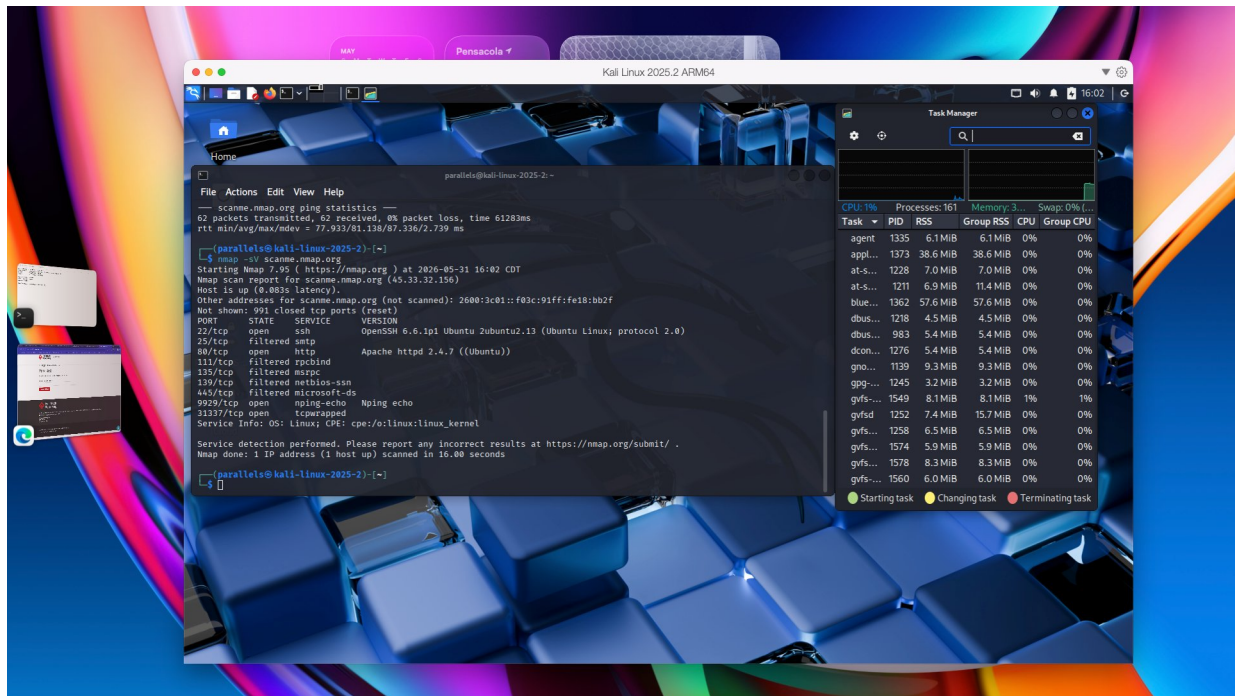


Figure 8.1 nmap -sV scanme.nmap.org completed in 16.00 seconds with 1 host confirmed up

Step 9 Port and Service Interpretation

Port	State	Service	Version Detected	Example Risk	Simple Defense
22/tcp	Open	SSH	OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)	OpenSSH 6.6.1p1 is significantly out of date and carries known CVEs. A publicly accessible SSH service is a common target for brute-force and credential-stuffing attacks from the internet.	Update to a current, supported OpenSSH version. Restrict inbound access to approved IP ranges. Require key-based authentication and disable password login entirely.
25/tcp	Filtered	SMTP	Not detected	A filtered state suggests a mail-related service blocked at the perimeter firewall. If ever misconfigured, it could be abused for open email relaying or spam delivery.	Maintain strict firewall rules on port 25. Limit outbound SMTP to authorized mail servers only and monitor for unusual outbound email volume.
80/tcp	Open	HTTP	Apache httpd 2.4.7 (Ubuntu)	Apache 2.4.7 was released in 2013 and is well past end-of-life. It carries multiple known CVEs including remote code execution paths. Unencrypted HTTP traffic is also susceptible to interception and modification in transit.	Upgrade Apache to a current supported release. Redirect all HTTP traffic to HTTPS. Place a Web Application Firewall in front of the service to detect and block common attack patterns.

Port	State	Service	Version Detected	Example Risk	Simple Defense
9929/tcp	Open	nping-echo	Nping echo	This service is intentionally exposed on scanme.nmap.org for testing. On any production system, non-standard open ports indicate misconfiguration and expand the available attack surface.	Audit all open ports against documented business need. Any service that cannot be justified should be disabled and firewalled immediately.
31337/tcp	Open	tcpwrapped	Not detected	Port 31337 is historically linked to backdoors and remote access tools. A tcpwrapped response means a service is listening but declined to identify itself to the scanner, which warrants immediate investigation.	Identify the process bound to this port using <code>ss</code> or <code>lsof</code> . If the service is not an authorized application, firewall or terminate it and investigate for signs of compromise.

Step 10 Active Reconnaissance Summary

The nmap service version scan of scanme.nmap.org revealed a system with a moderate but consequential attack surface. Three ports were confirmed open: SSH on port 22, HTTP on port 80, and two non-standard ports at 9929 and 31337. Five additional ports were in a filtered state, indicating that firewall rules are in place, though the services behind them may still be reachable under certain conditions.

The most pressing finding is the Apache version. Apache httpd 2.4.7, released in 2013, is far past end-of-life and is associated with multiple critical CVEs including remote code execution vulnerabilities. An outdated web server exposed directly to the internet with no authentication requirement represents the highest probability exploitation path on this system and would be the first service prioritized for hardening.

The SSH service on port 22 running OpenSSH 6.6.1p1 is the second priority. SSH is a necessary service for remote administration, but operating an outdated version with public internet exposure and no documented IP restriction creates meaningful risk of unauthorized access through credential-based attacks.

Two high-level recommendations stand out for a defender. First, both Apache and OpenSSH should be updated to current supported versions immediately, and HTTPS should be enforced for all web traffic with SSH access restricted to key-based authentication from approved source addresses. Second, the process bound to port 31337 should be identified and verified as an authorized service. Its historical association with backdoor tooling and its refusal to identify itself to the scanner warrant immediate investigation to rule out unauthorized remote access activity.